

RESPUESTA A INCIDENTES

> DFIR_CORE_MODULE_05_

Instructor: QBit |

| ¿Qué es Incident Response (IR)?

- **La Premisa:** En ciberseguridad no es "si" seremos vulnerados, sino "cuándo". IR es el enfoque estructurado para manejar las secuelas de un ataque.
- **El Objetivo:** Minimizar el impacto financiero, reputacional y operativo, reduciendo el tiempo de recuperación.
- **Evento vs Incidente:** Un "evento" es cualquier ocurrencia en el sistema. Un "incidente" es una violación inminente o real de las políticas de seguridad.
- El equipo de IR (CSIRT/CERT) actúa como los "bomberos digitales" ante amenazas como Ransomware o APTs.



| Metodología PICERL (Estándar SANS)



1. Preparación

Armado de políticas, playbooks de respuesta, configuración de herramientas forenses y entrenamiento continuo del equipo antes de que ocurra la crisis.



2. Identificación

Detectar el compromiso mediante alertas (SIEM, EDR), analizar registros y realizar un triage inicial rápido para confirmar que el incidente es real.



3. Contención

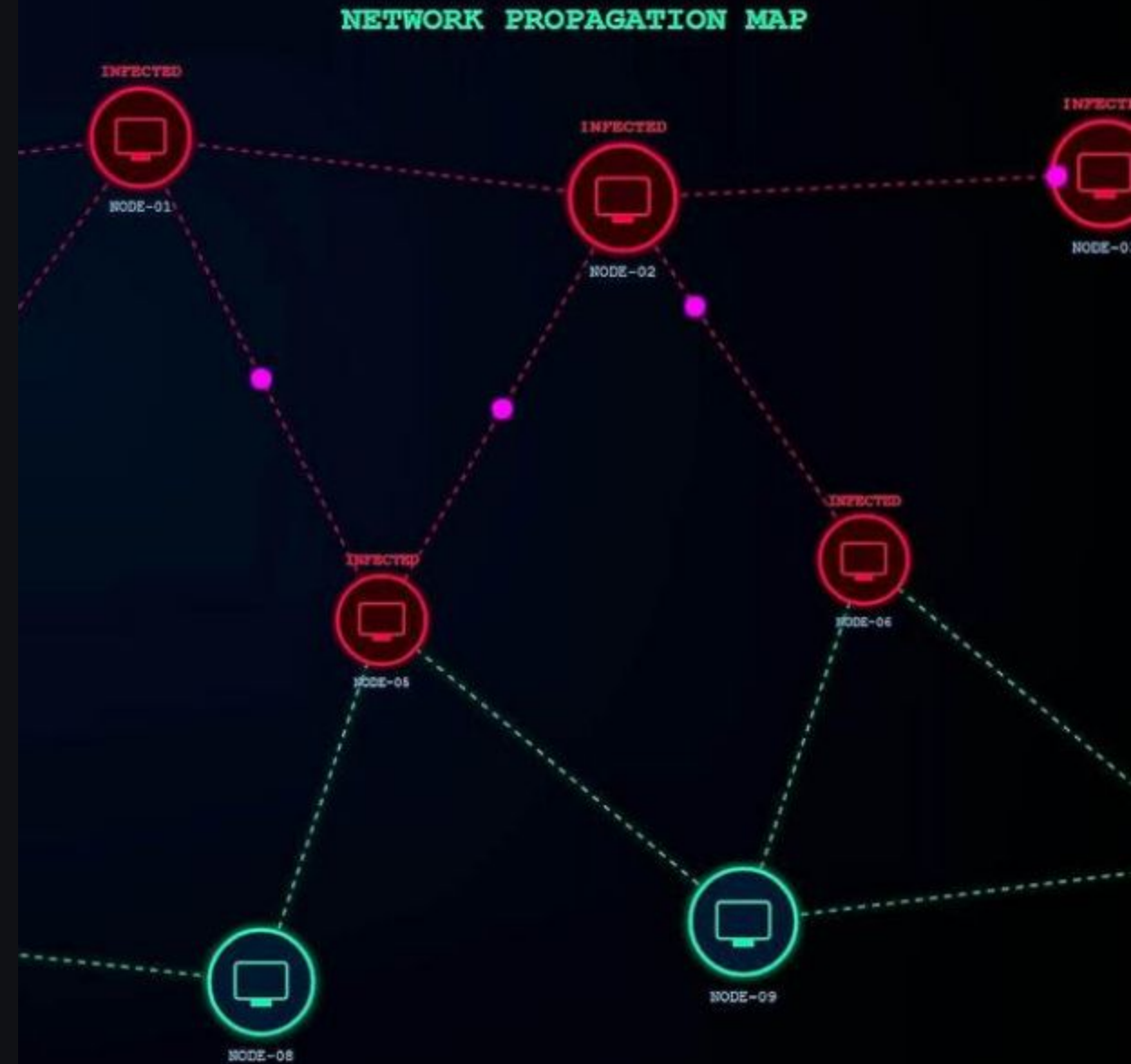
Mitigación inmediata. Aislar los hosts y redes comprometidas para detener la propagación lateral del atacante o la exfiltración de datos.

Identificación y Triage

El Reloj Comienza a Correr

La fase de Triage requiere distinguir bajo extrema presión los falsos positivos de los incidentes reales.

Se deben recolectar **IOCs (Indicadores de Compromiso)** de manera temprana: Direcciones IP maliciosas, hashes de archivos inusuales, o conexiones de red anómalas apuntando a servidores de Comando y Control (C2).



| Fase Crítica: Contención a Corto Plazo



Aislar la Amenaza (Air-Gapping)

Implica desconectar físicamente los cables de red, inhabilitar puertos en los switches o usar EDR para aislar lógicamente el host de la red corporativa.

LA REGLA DEL FIRST RESPONDER: ¡Nunca apagues el equipo infectado inmediatamente! Perderás la memoria RAM (evidencia volátil vital) y podrías detonar mecanismos de destrucción de datos (Wipers/Ransomware) programados al reinicio.

| Erradicación, Recuperación y Lecciones



4. Erradicación: Eliminación definitiva del malware, cierre de puertas traseras, bloqueo de cuentas comprometidas y remediación de la vulnerabilidad inicial (Root Cause).



5. Recuperación: Restauración progresiva de operaciones utilizando respaldos limpios validados (offline). Se reconectan los sistemas a producción bajo estricta vigilancia.



Cuarentena Lógica: Los sistemas recién restaurados operan bajo un monitoreo hiper-intensivo durante semanas para asegurar que no haya reinfección silenciosa.



6. Lecciones Aprendidas: Documentación y reunión post-mortem. ¿Qué falló en nuestras defensas? ¿Cómo mejoramos nuestros playbooks de respuesta para el futuro?

Orden de Volatilidad (RFC 3227)

2. Memoria RAM

Nanosegundos. Prioridad Forense
#1. Contiene procesos ocultos,
malware desempacado y claves
de cifrado en texto plano.

4. Discos Locales

Evidencia persistente (MFT,
Registry, archivos). Se adquiere
utilizando bloqueadores de
escritura y clonación bit a bit.

1. CPU / Caché

Milisegundos. Datos en registros
del procesador. Prácticamente
imposibles de capturar sin
hardware especializado.

3. Swap / Paginación

Archivos temporales del sistema
operativo que guardan
fragmentos de la memoria RAM
"derramada" en el disco.

Métricas de Rendimiento (KPIs en IR)

MTTD

Mean Time To Detect

Es el tiempo promedio que le toma a una organización descubrir una brecha de seguridad.

Bajar agresivamente el MTTD es el principal objetivo de los equipos de Threat Hunting y el SOC.

MTTR

Mean Time To Respond

El tiempo que toma aislar, controlar y erradicar la amenaza una vez detectada. Depende fuertemente de la automatización (soluciones SOAR) y la eficacia de los Playbooks predefinidos.

| La Mentalidad Analítica

||

Cualquier interacción con el sistema alterará irremediablemente su estado. Si debes interactuar para contener, documenta exhaustivamente qué hiciste, en qué momento exacto y por qué.

||

— Adaptación Forense del Principio de Intercambio de Locard

LABORATORIO 05

Adquisición de Memoria Viva y Volatility

1. Desplieguen la máquina virtual "Infectadax_05".
2. Creen un volcado íntegro de la RAM usando **LiME**.
3. Utilicen **Volatility3** con el plugin *linux.pslist* para encontrar el PID de la Reverse Shell.
4. Extraigan el binario malicioso inyectado desde la memoria al disco local.

```
>_ vol -f dump.lime linux.malfind.Malfind
```